

Cybersecurity, Information Security & Network Security

COMPREHENSIVE LECTURE HANDOUT

Fundamentals • Attacks • Defenses

Contents

1	Introduction and Core Concepts	3
1.1	Relationship Between the Three Domains	3
2	The CIA Triad — Foundation of Security	4
2.1	Extended Security Properties	4
3	Key Security Terminology	4
4	Security Models and Frameworks	5
4.1	Defense in Depth	5
4.2	The Principle of Least Privilege	5
4.3	Zero Trust Model	5
4.4	AAA Framework	6
5	Cryptography Fundamentals	6
5.1	Types of Encryption	6
5.2	Hashing	6
5.3	Digital Signatures and Certificates	6
6	Authentication Mechanisms	7
6.1	Authentication Factors	7
6.2	Password Security Best Practices	7
7	Network Security Fundamentals	7
7.1	The OSI Model and Security at Each Layer	7
7.2	Key Network Security Devices and Technologies	8
7.3	Network Security Architecture	8
7.4	Wireless Network Security	8
8	Common Cyber Attacks and Defenses	9
8.1	Social Engineering Attacks (Human Layer)	9

8.2	Network-Level Attacks	9
8.3	Application-Level Attacks	10
8.4	Malware Attacks (Endpoint Level)	11
8.5	Password Attacks	12
8.6	Advanced / Emerging Attacks	12
9	Summary: Attacks and Defenses at a Glance	13
10	Security Best Practices Checklist	13
11	Incident Response Lifecycle	14
12	Review Questions	14

1 Introduction and Core Concepts

Cybersecurity

The practice of protecting systems, networks, programs, and data from digital attacks, unauthorized access, damage, or disruption.

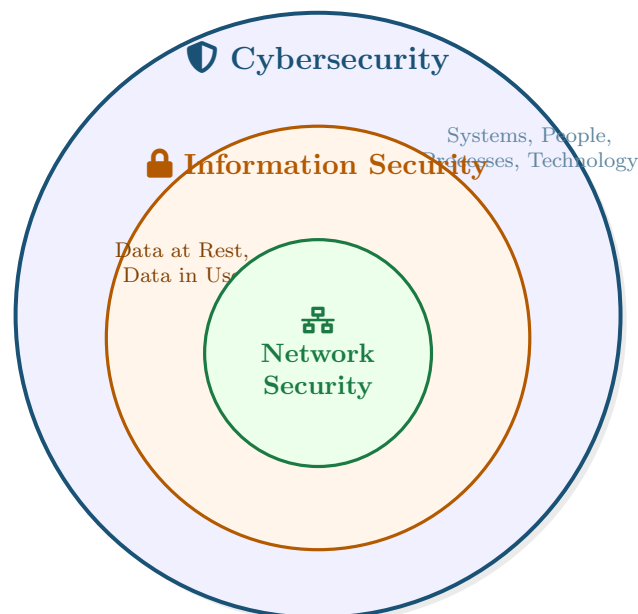
Information Security (InfoSec)

The practice of protecting information by mitigating risks. It involves preventing or reducing the probability of unauthorized access, use, disclosure, disruption, deletion, corruption, modification, or recording of data.

Network Security

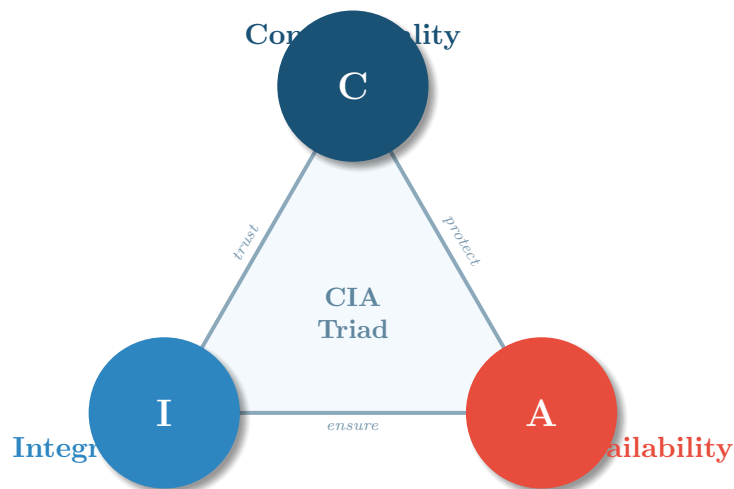
The set of policies, practices, and technologies designed to protect the integrity, confidentiality, and accessibility of computer networks and the data transmitted across them.

1.1 Relationship Between the Three Domains



- **Cybersecurity** is the broadest domain—covers all aspects of protecting digital assets (hardware, software, data, people, processes).
- **Information Security** focuses specifically on protecting *information* in any form (digital or physical).
- **Network Security** is a subset focused on protecting data *in transit* and network infrastructure.

2 The CIA Triad — Foundation of Security



Confidentiality

Ensuring that information is accessible only to those authorized to access it. Prevents unauthorized disclosure of data.

Example: Encryption, access control lists, authentication.

Integrity

Ensuring that information is accurate, complete, and has not been tampered with by unauthorized parties.

Example: Hashing (SHA-256), digital signatures, checksums.

Availability

Ensuring that information and resources are accessible to authorized users when needed.

Example: Redundancy, backups, load balancing, disaster recovery.

2.1 Extended Security Properties

- **Authentication:** Verifying the identity of a user, device, or system.
- **Authorization:** Determining what an authenticated user is permitted to do.
- **Non-repudiation:** Ensuring that a party cannot deny having performed an action (e.g., sending a message).
- **Accountability:** The ability to trace actions back to the responsible entity via logging and auditing.

3 Key Security Terminology

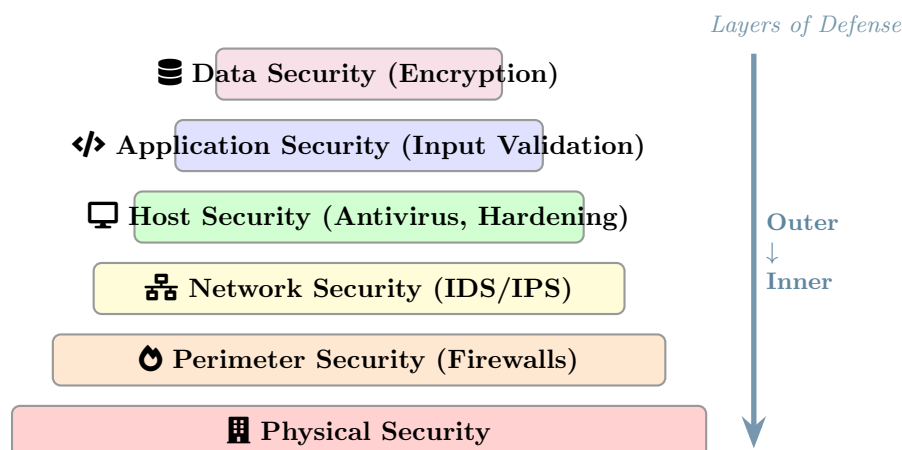
Term	Definition
Asset	Anything of value (data, hardware, software, personnel).
Threat	A potential cause of an unwanted incident that may harm an asset.

Term	Definition
Vulnerability	A weakness in a system that can be exploited by a threat.
Exploit	A technique or tool used to take advantage of a vulnerability.
Risk	The probability that a threat will exploit a vulnerability and cause harm. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
Attack Surface	The total set of points where an attacker can try to enter or extract data.
Threat Actor	An individual or group responsible for a cyber attack (hacker, insider, nation-state).
Zero-Day	A vulnerability unknown to the vendor with no available patch.
Patch	A software update that fixes a known vulnerability.
Payload	The malicious code delivered by an exploit.
Vector	The path or method used by an attacker to gain access.

4 Security Models and Frameworks

4.1 Defense in Depth

A layered security strategy where multiple defenses are placed throughout the system.



4.2 The Principle of Least Privilege

Users and programs should be granted only the minimum permissions needed to perform their tasks.

4.3 Zero Trust Model

🔍 Zero Trust

“Never trust, always verify.” Every access request is fully authenticated, authorized, and encrypted—regardless of whether it originates inside or outside the network perimeter.

4.4 AAA Framework

- **Authentication:** Who are you? (passwords, biometrics, tokens)
- **Authorization:** What can you do? (permissions, roles)
- **Accounting:** What did you do? (logging, auditing)

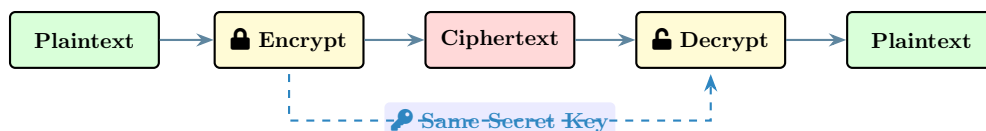
5 Cryptography Fundamentals

Cryptography

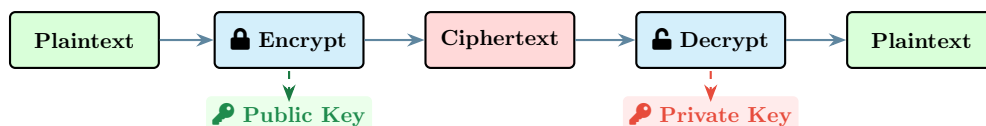
The science of securing communication and data through encoding so that only intended recipients can read it.

5.1 Types of Encryption

Symmetric Encryption (e.g., AES, DES)



Asymmetric Encryption (e.g., RSA, ECC)



Symmetric Encryption	Asymmetric Encryption
Same key for encryption & decryption	Two keys: public key & private key
Faster	Slower but more secure for key exchange
Key distribution is a challenge	Public key can be shared openly
Examples: AES, DES, 3DES, Blowfish	Examples: RSA, ECC, Diffie-Hellman

5.2 Hashing

Hash Function

A one-way function that converts input into a fixed-length output (digest). Used for integrity verification, *not* encryption.

Examples: MD5 (deprecated), SHA-1 (deprecated), SHA-256, SHA-3.

5.3 Digital Signatures and Certificates

- **Digital Signature:** Uses the sender's private key to sign a message; recipient verifies with sender's public key. Provides authentication, integrity, and non-repudiation.

- **Digital Certificate:** An electronic document issued by a Certificate Authority (CA) binding a public key to an identity.
- **PKI (Public Key Infrastructure):** The framework of policies, hardware, software, and procedures for managing digital certificates.

6 Authentication Mechanisms

6.1 Authentication Factors

1. **Something you know** — Password, PIN, security question.
2. **Something you have** — Smart card, security token, phone (OTP).
3. **Something you are** — Fingerprint, retina scan, facial recognition.

Multi-Factor Authentication (MFA)

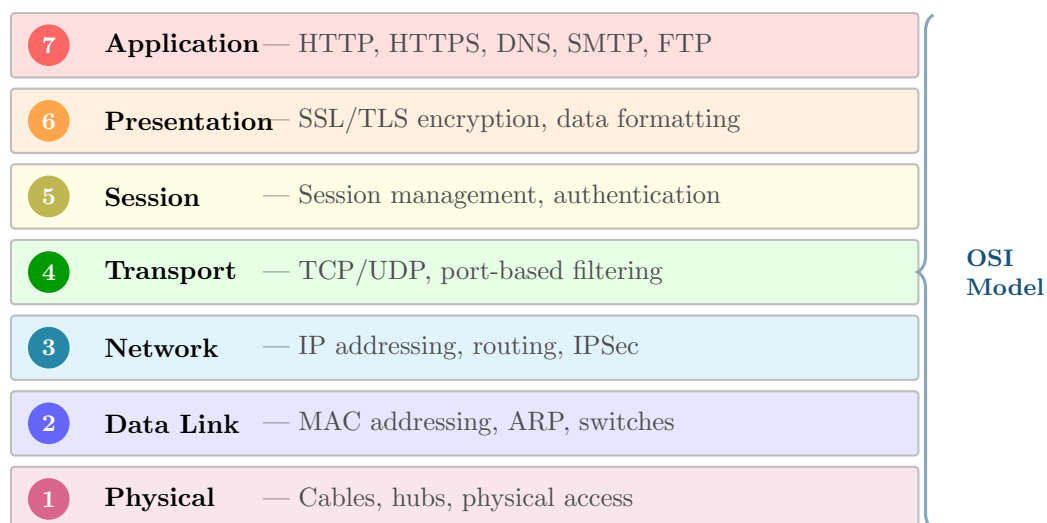
Using two or more authentication factors to verify identity. Significantly reduces the risk of unauthorized access.

6.2 Password Security Best Practices

- Use long, complex passwords (12+ characters)
- Use a password manager
- Never reuse passwords across services
- Enable MFA wherever possible
- Avoid dictionary words; use passphrases

7 Network Security Fundamentals

7.1 The OSI Model and Security at Each Layer



7.2 Key Network Security Devices and Technologies

Firewall

A device or software that monitors and filters incoming and outgoing network traffic based on predefined security rules. Types: packet-filtering, stateful inspection, application-layer (WAF), next-generation (NGFW).

Intrusion Detection System (IDS)

Monitors network traffic for suspicious activity and generates alerts. It is *passive*—it detects but does not block.

Intrusion Prevention System (IPS)

Similar to IDS but *active*—it can automatically block or prevent detected threats.

VPN (Virtual Private Network)

Creates an encrypted tunnel over a public network (internet) to securely connect remote users or sites. Protocols: IPSec, OpenVPN, WireGuard.

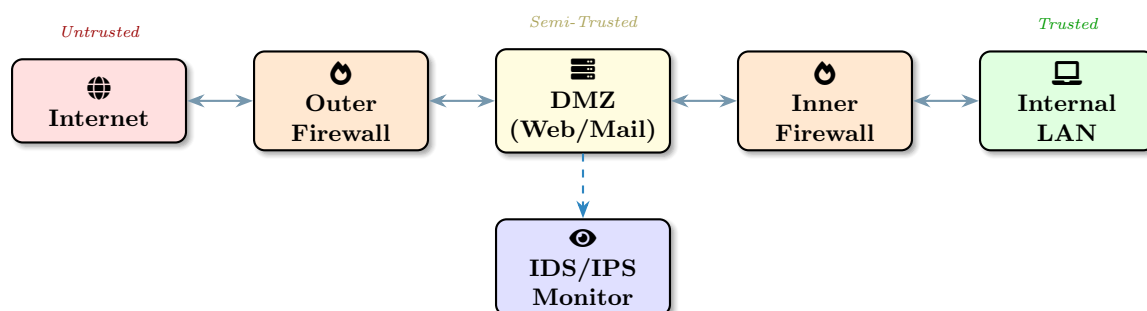
DMZ (Demilitarized Zone)

A network segment that sits between the internal network and the internet, hosting public-facing servers while isolating them from the internal network.

Proxy Server

An intermediary server that forwards requests between clients and servers. Provides anonymity, caching, and content filtering.

7.3 Network Security Architecture



7.4 Wireless Network Security

- **WEP (Wired Equivalent Privacy):** Deprecated; easily cracked.
- **WPA (Wi-Fi Protected Access):** Improved but still has weaknesses.
- **WPA2:** Uses AES encryption; current standard for most networks.
- **WPA3:** Latest standard with stronger encryption and protections against brute-force.

8 Common Cyber Attacks and Defenses

💡 Overview

Attacks are categorized below by the layer or domain they target: **Human** (social engineering), **Network**, **Application**, **Endpoint** (malware), **Password**, and **Advanced/Emerging**. Each entry includes a definition and recommended defenses.

8.1 Social Engineering Attacks (Human Layer)

⚠️ Phishing

Attack: Fraudulent emails, messages, or websites designed to trick users into revealing sensitive information (passwords, credit card numbers).

Defense: Security awareness training, email filtering, verifying sender identity, anti-phishing tools.

⚠️ Spear Phishing

Attack: A targeted phishing attack directed at a specific individual or organization using personalized information.

Defense: Employee training, verifying requests through alternate channels, email authentication (SPF, DKIM, DMARC).

⚠️ Social Engineering

Attack: Manipulating people into divulging confidential information through pretexting, baiting, tailgating, or quid pro quo.

Defense: Security awareness programs, strict access policies, visitor management procedures.

⚠️ Shoulder Surfing

Attack: Observing someone's screen or keyboard to steal information.

Defense: Privacy screens, awareness, shielding input when typing passwords.

⚠️ Dumpster Diving

Attack: Searching through discarded materials (trash) to find sensitive information.

Defense: Shredding documents, secure disposal policies, encrypting discarded drives.

8.2 Network-Level Attacks

⚠️ Denial of Service (DoS)

Attack: Overwhelming a system, server, or network with traffic to make it unavailable to legitimate users.

Defense: Rate limiting, traffic filtering, redundant infrastructure, content delivery networks (CDNs).

⚠️ Distributed Denial of Service (DDoS)

Attack: A DoS attack launched from multiple compromised systems (botnet) simultaneously.

Defense: DDoS mitigation services (e.g., Cloudflare), traffic analysis, load balancing,

ISP-level filtering.

⚠ Man-in-the-Middle (MitM)

Attack: The attacker secretly intercepts and possibly alters communication between two parties who believe they are communicating directly.

Defense: Use HTTPS/TLS, certificate pinning, VPNs, avoid public Wi-Fi for sensitive transactions.

⚠ ARP Spoofing / ARP Poisoning

Attack: Sending fake ARP messages to link the attacker's MAC address with a legitimate IP address, enabling traffic interception.

Defense: Static ARP entries, Dynamic ARP Inspection (DAI), network segmentation.

⚠ DNS Spoofing / DNS Poisoning

Attack: Corrupting the DNS cache to redirect users to malicious websites.

Defense: DNSSEC, secure DNS resolvers (DoH/DoT), regular cache flushing.

⚠ IP Spoofing

Attack: Forging the source IP address in packets to impersonate another system.

Defense: Ingress/egress filtering, packet authentication, IPSec.

⚠ Packet Sniffing / Eavesdropping

Attack: Capturing network packets to read unencrypted data (passwords, emails).

Defense: Encrypt traffic (TLS/SSL, VPN), use switched networks, network monitoring.

⚠ Session Hijacking

Attack: Stealing or predicting a valid session token to gain unauthorized access to a web application.

Defense: Use HTTPS, regenerate session IDs after login, set secure/HttpOnly cookie flags, session timeout.

8.3 Application-Level Attacks

⚠ SQL Injection (SQLi)

Attack: Inserting malicious SQL code into input fields to manipulate or access the database.

Defense: Parameterized queries (prepared statements), input validation, ORM frameworks, least privilege DB accounts.

⚠ Cross-Site Scripting (XSS)

Attack: Injecting malicious scripts into web pages viewed by other users to steal cookies, session tokens, or redirect users.

Defense: Output encoding, Content Security Policy (CSP), input sanitization, HttpOnly cookies.

⚠ Cross-Site Request Forgery (CSRF)

Attack: Tricking a logged-in user's browser into making an unwanted request to a web application.

Defense: Anti-CSRF tokens, SameSite cookie attribute, re-authentication for sensitive actions.

⚠ Buffer Overflow

Attack: Writing more data to a buffer than it can hold, causing adjacent memory to be overwritten, potentially allowing code execution.

Defense: Input validation, bounds checking, ASLR (Address Space Layout Randomization), DEP (Data Execution Prevention), safe coding practices.

⚠ Remote Code Execution (RCE)

Attack: Exploiting a vulnerability to execute arbitrary code on a remote system.

Defense: Regular patching, input validation, sandboxing, least privilege.

⚠ Directory Traversal

Attack: Exploiting insufficient input validation to access files outside the intended directory (e.g., using `../../etc/passwd`).

Defense: Input validation, chroot jails, restrict file system permissions.

8.4 Malware Attacks (Endpoint Level)

⚠ Virus

Attack: A malicious program that attaches itself to legitimate files and spreads when the host file is executed.

Defense: Antivirus software, avoid untrusted downloads, keep systems updated.

⚠ Worm

Attack: Self-replicating malware that spreads across networks without user interaction.

Defense: Firewalls, IDS/IPS, network segmentation, patch management.

⚠ Trojan Horse

Attack: Malware disguised as legitimate software that provides unauthorized access or performs malicious actions.

Defense: Download software from trusted sources, antivirus, application whitelisting.

⚠ Ransomware

Attack: Malware that encrypts the victim's files and demands a ransom payment for decryption.

Defense: Regular backups (offline/offsite), patch management, email filtering, endpoint detection and response (EDR).

⚠ Spyware

Attack: Software that secretly monitors user activity and collects personal information.

Defense: Anti-spyware tools, avoid suspicious downloads, regular scans.

⚠ Rootkit

Attack: Malware that hides its presence and provides continued privileged access to a system.

Defense: Integrity checking tools, secure boot, rootkit scanners, reinstallation if detected.

⚠ Keylogger

Attack: Software or hardware that records keystrokes to capture passwords and sensitive data.

Defense: Anti-keylogger software, virtual keyboards, MFA, endpoint protection.

⚠ Botnet

Attack: A network of compromised computers (bots/zombies) controlled by an attacker, often used for DDoS or spam.

Defense: Antivirus, firewalls, intrusion detection, regular patching, network monitoring.

8.5 Password Attacks

⚠ Brute Force Attack

Attack: Systematically trying every possible combination of characters to guess a password.

Defense: Account lockout policies, strong passwords, CAPTCHA, MFA, rate limiting.

⚠ Dictionary Attack

Attack: Using a list of common words and known passwords to guess credentials.

Defense: Complex passwords, avoid common words, salted hashing.

⚠ Rainbow Table Attack

Attack: Using precomputed hash-to-password lookup tables to crack hashed passwords.

Defense: Use salted hashes, strong hashing algorithms (bcrypt, Argon2).

⚠ Credential Stuffing

Attack: Using stolen username/password pairs from data breaches to access other services.

Defense: Unique passwords per service, MFA, breach monitoring.

8.6 Advanced / Emerging Attacks

⚠ Advanced Persistent Threat (APT)

Attack: A prolonged, targeted cyber attack where an intruder gains access and remains undetected for an extended period.

Defense: Network monitoring, threat intelligence, segmentation, incident response planning, EDR.

⚠ Zero-Day Exploit

Attack: Exploiting a previously unknown vulnerability before a patch is available.

Defense: Behavioral detection, sandboxing, threat intelligence, rapid patch deployment.

⚠ Supply Chain Attack

Attack: Compromising a trusted third-party vendor or software update mechanism to distribute malware.

Defense: Vendor assessment, code signing verification, software bill of materials (SBOM), integrity checks.

⚠ Insider Threat

Attack: A current or former employee, contractor, or business associate who misuses authorized access to harm the organization.

Defense: Least privilege, user activity monitoring, background checks, separation of duties.

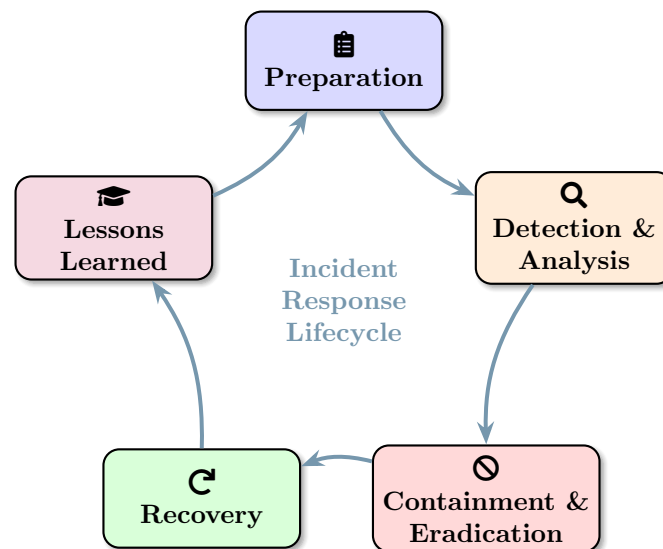
9 Summary: Attacks and Defenses at a Glance

Layer	Attack	Target	Key Defense
Human	Phishing	Users	Training, email filters
Human	Social Engineering	Users	Awareness, policies
Network	DoS/DDoS	Servers	Rate limiting, CDN, filtering
Network	MitM	Communication	TLS, VPN, cert pinning
Network	ARP Spoofing	LAN	DAI, static ARP
Network	DNS Spoofing	DNS	DNSSEC, secure resolvers
Network	Sniffing	Traffic	Encryption, VPN
Application	SQL Injection	Database	Parameterized queries
Application	XSS	Web users	CSP, output encoding
Application	CSRF	Web sessions	Anti-CSRF tokens
Application	Buffer Overflow	Memory	ASLR, DEP, bounds check
Endpoint	Ransomware	Files	Backups, EDR, patching
Endpoint	Virus/Worm	Systems	Antivirus, segmentation
Endpoint	Rootkit	OS	Integrity checks, secure boot
Password	Brute Force	Credentials	Lockout, MFA, rate limit
Password	Rainbow Table	Hashes	Salted hashing
Advanced	APT	Organization	Monitoring, threat intel
Advanced	Zero-Day	Any	Behavioral detection
Advanced	Supply Chain	Software	Code signing, SBOM

10 Security Best Practices Checklist

- ✓ Keep all software updated and patched
- ✓ Use strong, unique passwords with MFA
- ✓ Encrypt sensitive data at rest and in transit
- ✓ Implement the principle of least privilege
- ✓ Conduct regular security awareness training
- ✓ Perform regular backups (3-2-1 rule)
- ✓ Deploy firewalls and IDS/IPS
- ✓ Segment networks appropriately
- ✓ Monitor and log all access and activities
- ✓ Have an incident response plan
- ✓ Conduct regular vulnerability assessments
- ✓ Implement endpoint protection
- ✓ Use secure coding practices
- ✓ Verify third-party software integrity

11 Incident Response Lifecycle



1. **Preparation:** Establish policies, tools, and a response team.
2. **Detection & Analysis:** Identify and investigate security incidents.
3. **Containment & Eradication:** Isolate affected systems and remove the threat.
4. **Recovery:** Restore systems to normal operations.
5. **Lessons Learned:** Review the incident to improve future response.

12 Review Questions

1. Define the CIA triad and give one example for each property.
2. What is the difference between a vulnerability, a threat, and an exploit?
3. Compare symmetric and asymmetric encryption with examples.
4. Explain the difference between IDS and IPS.
5. What is a Man-in-the-Middle attack and how can it be prevented?
6. Describe three types of malware and their defenses.
7. What is the principle of least privilege and why is it important?
8. How does SQL injection work and what are the best defenses?
9. Explain the Defense in Depth strategy with an example.
10. What is multi-factor authentication and why is it recommended?